

→ application attacks

- attacks on applications in networked systems can target the server, client or both
- server side
 - ↳ exploit the web server or backend e.g. database.
- client side
 - ↳ exploit the browser e.g. XSS
- both
 - ↳ attacks like CSRF

→ server side web application attacks.

- securing server side web app is often harder.
- traditional firewalls IDS ignore HTTP content, so they can't block many web attacks
- zero-day attack: exploits unknown vulnerabilities, victims have no defense ready.
- many attacks target user input
 - ↳ cross-site scripting (XSS)
 - ↳ SQL Injection
 - ↳ XML Injection
 - ↳ Command Injection

SQL INJECTION

→ databases store and manipulate data in tables.

→ provides semantics, transactions, query language, permissions.

→ ACID transactions

- ↳ atomicity: transaction complete entirely or not at all.
- ↳ consistency: always in a valid state but not correct necessarily.
- ↳ isolation: results are not visible until complete.
- ↳ durability: committed changes survive crashes.

→ SELECT retrieves data

Select **column_name** FROM **table_name** WHERE **condition**

→ UPDATE, INSERT, DELETE, DROP modify

update **tablename** SET **condition** WHERE **condition**

insert into **tablename** values ()

→ google dorking

↳ find potentially vulnerable sites.

→ SQL Injection

↳ select * from user accounts WHERE username = 'admin' -- 'AND pass = 'f'

↳ drop tables

• countermeasures

↳ blacklisting: strip dangerous chars (', --, ;)

↳ whitelisting: accept only expected formats, reject invalid input entirely.

↳ escape characters: convert characts (; → \ ;) (- → \ -)

• problem

↳ string concatenation blurs code and data (input)

• countermeasure

↳ bind variables: keep placeholders (?) for user and password.

\$statement → bind_param ("ss", \$user, \$pass)

\$statement → execute ();

query compiled once, parameters filled later

first prepare then bind

\$statement = \$db → prepare (select * from users

where user = ? and password = ?);

Date:

→ query execution phase

↳ parsing & normalization phase : syntax , semantic check

↳ compilation : convert query into machine understandable

↳ query optimization : all possible ways to execute

↳ cache : stores

↳ prepare : replacing ? with the data, no recompilation

↳ execution

→ mitigating impact

↳ least privilege : DB user can only select , insert , not DROP

↳ encrypt sensitive data , store hash passwords

ARP POISONING

→ maps 32-bit IP address to 48 bit MAC Address

→ each host/router on a LAN maintains an ARP Table (also called cache)

→ entries have TTL (time to live) ; windows default is 60 seconds for dynamic entries , 15-20 minutes for static

→ ARP operates at link layer

→ A must have B's MAC address to send packets , a broadcast message is sent to first receive B's MAC address

→ ARP is a request - response protocol → ARP replies are not authenticated.

↳ attacker sends forged ARP replies to associate any chosen IP with their own MAC

↳ requires attacker to be on same LAN

↳ in a switched network , legitimate traffic between two hosts is not visible to a third host

→ ARP Poisoning: Man in the Middle

- attacker continuously sends ARP replies to Host A and B claiming MAC address.
- Host A and B update ARP table with false entry
- attacker also poisons gateway, replies that A and B IP are at my MAC.
- all traffic between host & gateway goes through attacker.

→ ARP poisoning: DoS Attack

- attacker sends forged ARP replies telling host that gateway IP is at fake MAC " "
- Hosts updates ARP tables with fake MAC
- When hosts send packets to gateway, switch has no port for that fake MAC → packets are dropped.

→ preventions

- static ARP entries: manually configure fixed IP → MAC mappings.
- limit local access: prevent unauthorized devices from joining the LAN
- dynamic ARP inspection: validates ARP packets against a trusted binding table.
- port security: restricts MAC address per switch port
- ARP spoofing detection tools.
- network segmentation to shrink broadcast domains.
- encryption: data remains confidential

→ SLAAC Attack

- hosts configure addresses from router advertisements without DHCP (RA)
- 1. attacker connects rogue IPv6 router to the network
- 2. rogue sends unsolicited RA messages with its prefix; claims to be default
- 3. Host accepts RA → auto-configure IPv6 address using attacker's prefix & set rogue as default gateway.
- 4. Modern OS prefer IPv6 over IPv4 → all outbound traffic goes through attacker

→ security implications

- data exposure, phishing, malware risks, network disruption.

→ prevention

- RA guard on switches to block unauthorized RA message.
- limit connection.
- monitor IPv6 traffic and configuration for unusual activity.
- cryptographic protection

COOKIES

- small pieces of data sent from a web server to the client's browser
- browser stores them and sends them back with subsequent requests to the same domain
- Key-value pairs stored in the browser
- they solve HTTP's stateless nature by allowing servers to remember clients
- HTTP is stateless; each request-response is independent
- web app needs to maintain a user state as how does the server know if two requests come from the same browser?

↳ use of cookies

↳ use of hidden fields.

- after logging in to a website, a cookie is set with the session ID. The server recognizes you without asking you to login again on every page.

- cookies provide a token.

- ↳ keeps you logged in, set via Set-Cookie header in response

- ↳ remembers preference

- ↳ monitor user activity

- hidden field approach

- ↳ include HTML form field and session ID in form

- ↳ submitted with GET/POST data

- ↳ session ends when browser closed

- ↳ every page dynamically generated.

- cookie is sent over HTTPS protocol

- 1st party cookie: set by site you're visiting.

- 3rd party cookie: set by embedded content — cross-site tracking

- browser fingerprint is alternate for tracking.

- session hijacking & cookie theft

- cookies act as capabilities — grants access

- impersonation (act as victim)

- through network sniffing, server compromise, prediction,

- DNS caching

- defense include HTTPOnly flag, Secure Flag, long token IDs

CROSS-SITE REQUEST FORGERY (CSRF)

- attacker tricks a victim's browser into sending unauthorized requests to a site where the victim is authenticated
- performs action as victim (transfer money)
- server sees request as legitimate because session cookies are included.
- targets state-changing operations (POST, PUT, DELETE)
- victim visits a malicious link that triggers action on authenticated site.
- defense: referer validation
 - request header contains address of previous web page
 - weak referer can be removed forcefully.
- defense: secret token, synchronizer
 - server generates unique token per session.
 - embed in forms/links
 - on submit, server verifies token matches session
 - attacker can't set/read cookie across site
 - per request tokens stricter but usability issue.
- defense: double submit cookie
 - set CSRF token as cookie & also in form header
 - server checks if they match
 - same-origin prevents attacker from read/set on target domain.
 - stateless (no storage)
- defense: samesite cookie
 - no cross-site request at all → strict A.com → A.com
 - lax: allows safe method + top-level GET A.com → B.com
 - banking → strict flag
 - lax is blocked for POST request in cross-site subrequests

CROSS-SITE SCRIPTING

XSS: SUBVERTING THE SOP

- The attacker's site (attacker.com) provides a malicious script. The goal is to make user's browser believe that the script's origin is a trusted site, such as bank.com

XSS

- security vulnerability found in web applications
- attack occurs when attacker injects malicious scripts into content that is delivered to users
- lead to data theft, session hijacking

TYPES OF XSS

1. STORED OR PERSISTENT

- malicious script is permanently stored on the target server often in a database
- when other users view database, their browser execute the script
- target: a user with a JS-enabled browser who visits user-influenced content on a vulnerable web service

2. REFLECTED XSS

- attacker gets the victim to send trusted server (bank.com) a URL that includes JS.
- the trusted server then echoes the script back to the user in its response
- user's browser executes the script in the response within the same trusted origin.
- in echo data is echoed back without any proper validation.
- attacker needs: to get to the user to click on a specially crafted URL
- defense: sanitizing the input, removing executable portions of user-provided content.
- Content Security Policy allows server administrator to eliminate XSS attack by specifying the domain that the browser should consider to be valid sources of exe scripts.

BLOCKCHAIN

- it is a decentralized and distributed digital ledger system that records transactions across many computer nodes
 - decentralized: no single authority controls the system.
 - distributed: every participant has a copy of the ledger
 - tamper-resistant: once data is recorded, hard to change
- example: bitcoin is sent to someone, thousands of computers verify and store the same transaction record.

TRANSACTION PROCESS

1. Initiate a transaction
 - user requests an action
2. Verification
 - transaction broadcast to all network nodes which can verify it.
3. Block Creation
 - verified transaction grouped into a block
4. Consensus and Finalization
 - Nodes agree and add the block permanently to the blockchain

STRUCTURE

- each block contains
 - transaction data
 - own hash
 - hash of the previous block
- blocks are linked chronologically; first block is called "genesis"
- every node stores a copy of blockchain
- rules that nodes use to agree
 - proof of work (PoW): miners solve complex puzzle to prevent fraud
 - proof of stake (PoS)

KEY FEATURES

- Immutable: once recorded, data cannot be changed.
- transparency: everyone can view transactions.
- security: cryptography ensures data integrity.
- decentralization: no single point of failure.

→ blockchain introduces trust with intermediaries

→ everyone can verify data, but no one can control or manipulate

ADVANTAGES

1. TRANSPARENCY

→ share same ledger

→ can only be updated through consensus.

2. ENHANCED SECURITY

→ transactions are verified, encrypted, linked

→ data exists on many nodes so hacking one computer doesn't compromise

3. IMPROVED TRACEABILITY

→ creates full audit trail

4. INCREASED EFFICIENCY

→ automation removes intermediaries

→ cross-border payments can take minutes.

5. REDUCED COSTS

→ no middlemen, fewer audits, no central infrastructure.

DISADVANTAGES

1. 51% ATTACKS

→ if one entity controls >50% of network power, it can manipulate data.

→ expensive on large networks

2. DATA MODIFICATION

→ data is hard to change once added

→ fixing it requires consensus & new blocks.

3. PRIVATE KEYS

→ must protect private key. if lost, your funds are lost

4. INEFFICIENCY

→ only one miner wins and adds the block,

5. STORAGE

→ blockchain size grows rapidly, often nodes are lost

6. POWER WASTAGE

→ consumes massive energy

ACCESS CONTROL

- managing and limiting access to resources.
- physical access
 - entry to building, labs
- logical access:
 - access to computer, files, database
- users have different access modes:
 - read, write, append, execute, delete, create, search
- access control
 - organizations must restrict access to protect their assets
 - it is policy-driven
- access control protections
 - identification: who are you?
 - authentication: are you who you say you are?
 - authorization: what are you allowed to do?
 - auditing: what did you actually do?
 - accountability: holding users responsible
 - non-repudiation: you cannot deny your actions.

1. IDENTIFICATION

- uniquely recognizes a user
- must be unique, should not reveal sensitive info.
- uses standardized naming schemes

2. AUTHENTICATION

- verifies identity using credentials.
- what you know: password
- what you have: access card
- what you are: fingerprint
- what you do: signature
- use 2 different authentication methods.
- reusable vs one-time password
- password cracking risks
- password policies
 - not using same password at multiple sites
 - social engineering

- secure password storage as hashes
- many companies are replacing passwords due to weaknesses.
 - google uses security keys and biometrics
- access cards
 - magnetic stripe card
 - smart cards
- tokens
 - one time password token for each device separately.
 - USB token.
 - proximity access tokens.
 - near the place to be recognized.
 - addresses loss and theft, often require PIN.
- biometric authentication
 - based on biological measurements.
 - fingerprint, face, iris, voice
 - enrollment: an initial scan taken, key features processed, template stored
 - matching errors:
 - * since no two scans are same, a configurable match index is used to determine how close the match must be
 - * false acceptance rate: The percentage of impostors who are incorrectly identified as a match (lower is better)
 - * false rejection rate: The percentage of legitimate users who are incorrectly rejected - (lower is better)
 - * failure to enroll: when a subject cannot enroll in the system (poor fingerprints)
 - * deception: when subject tries to fool the system.
 - verification
 - supplicant claims an identity and the system compares the scan to a single template. good for replacing passwords.
 - identification
 - supplicant does not state an identity & system compares the scan to all templates in the database to find a match. used for door access or watchlists
 - carries much higher risk of false acceptance as there are many template.

- fingerprint recognition: simple, inexpensive, common, vulnerable to deception.
- iris recognition: low false acceptance, highly secure but expensive
- face recognition: high error rates.
- voice recognition: easily deceived by recordings, high error rates.
- other forms: veins in hand, keystroke recognition, signature recognition
gait (the way person walks)

→ cryptographic

- use of digital keys e.g. SSH
- issue of key management and trust in public keys
- public key infrastructure verifies public keys.
- private keys must never be shared & securely stored (HSM)

AUTHORIZATION

→ process of assigning permission to an authenticated individual or role, determining what they are allowed to do with a resource.

→ principle of least permission

- users should initially be given only the permission absolutely needed to perform their job.
- giving extensive or full permissions initially is bad practice because it increases risk of errors.

→ individual and role based access control

- for individuals, access rules are based on specific user accounts.
- for role-based, access rules are based on the user's assigned role, making management easier.
e.g. all users in "HR Manager" role are granted access to the payroll system.
- human and organizational controls.

$$1 \leq e \leq \phi(n)$$

→ mandatory and discretionary access control

- often used in high security environments.

- MAC

- access rules are set by central authority & cannot be altered by departmental or personal users. Difficult to implement.

- DAC

- users have the ability to access a file they created / resources they own. It is decentralized & based on identities of the users.

example: In DAC, a user can grant or revoke access to a file they created. In MAC, only central security policy dictates who can access the file, regardless of who created it.

→ multilevel security.

- classifies both data and users by security levels; confidential, secret, top secret. Users can only access information for which they have the required clearance level.

AUDITING

→ process of logging & reviewing what an authenticated & authorized person actually did.

→ logging

- events such as logins, failed login attempts, file deletion, and system changes are recorded in a log file.

→ log reading

- regular log-reading is crucial, otherwise log becomes useless

write only memory

- periodic external audits

- automatic alerts for strong threats.

DIGITAL SIGNATURE

→ a cryptographic technique used to verify that a digital message or document :

- was sent by the claimed sender (authenticity)
- has not been changed in transit (integrity)
- cannot be denied later by the sender (non-repudiation)

WORKING

1. The sender generates a hash (short fixed length) of the message using a hash function.
2. The sender encrypts that hash using their private key - this encrypted hash is the digital signature.
3. The original message + digital signature are sent to the receiver.
4. The receiver decrypts the signature using sender's public key.
5. The receiver also recomputes the hash of the received message.
6. If the decrypted hash matches the recomputed hash - message is authentic and unchanged.

DIGITAL VS ELECTRONIC

→ a digital signature is a specific type of electronic signature

→ electronic signature includes:

- typing a name
- clicking an 'I Agree' button
- upload a scanned handwritten signature

→ DS used for high-security & legally sensitive documents. and uses cryptographic security

→ DS : legal documents, sales agreement, financial documents, healthcare

DIFFIE HELLMAN

- choose a prime number $\rightarrow p$
 choose a generator $\rightarrow g$

} public
- Person 1 chooses a private number $\rightarrow a$
 Person 2 chooses a private number $\rightarrow b$

} private
- Person 1 computes public value
 $A = g^a \text{ mod } p$
 Person 2 computes public value
 $B = g^b \text{ mod } p$

} share with each other only
- Person 1 computes shared secret
 $K = B^a \text{ mod } p$
 Person 2 computes shared secret
 $K = A^b \text{ mod } p$

} both get same secret key

Example

1,2 $p = 97$ $g = 5$ Alice private number = 36 = a
 Bob, private number = 58 = b

3. build a squaring table for $g \text{ mod } p \rightarrow 5 \text{ mod } 97$

Power	Calculation	Value mod 97
5^1	5	5
5^2	$5 \times 5 = 25$	25
5^4	$25 \times 25 = 625$	$625 - 6 \times 97 = 43$
5^8	$43 \times 43 = 1849$	$1849 - 19 \times 97 = 6$
5^{16}	$6 \times 6 = 36$	36
5^{32}	$36 \times 36 = 1296$	$1296 - 13 \times 97 = 35$
5^{64}	$35 \times 35 = 1225$	$1225 - 12 \times 97 = 61$

$$A = 5^{36} \text{ mod } 97 \rightarrow 5^{32} \cdot 5^4 \text{ mod } 97$$

$$A = 35 \times 43 = 1505 \text{ mod } 97 = 1505 - 15 \times 97 = 50$$

$$B = 5^{58} \text{ mod } 97 \rightarrow 5^{32} \cdot 5^{16} \cdot 5^8 \cdot 5^2 \text{ mod } 97$$

$$B = 35 \times 36 \times 6 \times 25 = 189000 \text{ mod } 97 = 189000 - 1948 \times 97 = 44$$

4. Person 1 $\rightarrow K = B^A \text{ mod } p$

$$K = 44^{30} \text{ mod } 97$$

Person 2 $\rightarrow K = A^B \text{ mod } p$

$$K = 50^{58} \text{ mod } 97$$

Power	Calculation	value mod 97
44^1	44	44
44^2	$44 \times 44 = 1936$	$1936 - 19 \times 97 = 93$
44^4	$93 \times 93 = 8649$	$8649 - 89 \times 97 = 16$
44^8	$16 \times 16 = 256$	$256 - 2 \times 97 = 62$
44^{16}	$62 \times 62 = 3844$	$3844 - 39 \times 97 = 61$
44^{32}	$61 \times 61 = 3721$	$3721 - 38 \times 97 = 35$

$$K = 44^{32} \cdot 44^4 \text{ mod } 97$$

$$K = 35 \times 16 \text{ mod } 97 = 560 - 5 \times 97 = 75$$

Power	Calculation	value mod 97
50^1	50	50
50^2	$50 \times 50 = 2500$	$2500 - 25 \times 97 = 75$
50^4	$75 \times 75 = 5625$	$5625 - 57 \times 97 = 96$
50^8	$96 \times 96 = 9216$	$9216 - 95 \times 97 = 1$
50^{16}	$1 \times 1 = 1$	1
50^{32}	$1 \times 1 = 1$	1
50^{64}	$1 \times 1 = 1$	1

$$K = 50^{32} \cdot 50^{16} \cdot 50^8 \cdot 5^2$$

$$K = 1 \times 1 \times 1 \times 75 \text{ mod } 97 = 75$$

RSA

1. choose two prime numbers $\rightarrow p, q$
2. compute $n = p * q$
3. compute $\phi(n) = (p-1) * (q-1)$
4. choose public e
 $\gcd(e, \phi(n)) = 1$
 $1 < e < \phi(n)$
5. find d such that
 $e * d \equiv 1 \pmod{\phi(n)}$
6. encryption $\rightarrow C = M^e \pmod{n}$
7. decryption $\rightarrow M = C^d \pmod{n}$

EXAMPLE

1. $p = 71, q = 67, M = 80$
2. $n = 71 * 67 = 4757$
3. $\phi(n) = (71-1) * (67-1) = 4620$
4. $1 < e < 4620$
 $\gcd(13, 4620)$ are coprime
 $e = 13$

public key $(e, n) = (13, 4757)$

private key $(d, n) =$

5. $e * d \equiv 1 \pmod{\phi(n)}$
 $13 * d \equiv 1 \pmod{4620}$
 $13 * d \pmod{4620}$

Division	Quotient	Remainder
$4620 \div 13$	355	5
$13 \div 5$	2	3
$5 \div 3$	1	2
$3 \div 2$	1	1
$2 \div 1$	2	0

now back substitute from last non-zero remainder

- $3 = (2 \times 1) + 1 \rightarrow \text{rearrange} \rightarrow 1 = 3 - (2 \times 1)$
 $5 = (3 \times 1) + 2 \rightarrow \text{rearrange} \rightarrow 2 = 5 - (3 \times 1)$
 $13 = (5 \times 2) + 3 \rightarrow \text{rearrange} \rightarrow 3 = 13 - (5 \times 2)$
 $4620 = (13 \times 355) + 5 \rightarrow \text{rearrange} \rightarrow 5 = 4620 - (13 \times 355)$

- $1 = 3 - (2 \times 1)$
 $1 = (13 - (5 \times 2)) - (5 - (3 \times 1))$
 $1 = 13 - (2 \times (4620 - (13 \times 355))) - (4620 - (13 \times 355) - 3)$
 $1 = 13 - (2 \times 5) - (5 - 3)$

- $1 = 3 - (2 \times 1)$
 $2 = 5 - (3 \times 1) = 1 = 3 - (5 - 3 \times 1) = 2 \times 3 - 5$
 $3 = 13 - (5 \times 2) = 2 \times (13 - 5 \times 2) - 5 = -5 \times 2 + 2 \times 13$

$$1 = (13 - 2 \times [-5(13 \times 2) + 1]) - (4620 - (13 \times 355) - 3)$$

$$(2 \times 13) (2 \times -5 \times 2) - 5 = 15$$

$$(2 \times 13) - 20 - 5 = 1$$

$$(2 \times 13) - 25 = 1$$

$$(2 \times 13) - 5(5) = 1$$

- $5 = 4620 - (13 \times 355) = (2 \times 13) - 5(4620 - 13 \times 355)$
 $= (2 \times 13) - 5(4620 - 13 \times 355)$
 $(2 \times 13) - 5 \times 4620 + 5(13 \times 355)$
 $(2 \times 13) + 5(13 \times 355) - 5(4620)$
 $13(2 + 5 \times 355) - 5(4620)$
 $13(1777) - 5(4620)$

$$d = 1777$$

6. $C = M^e \bmod n$

$C = 80^{13} \bmod 4757$

power	calculation	value mod 4757
80^1	80	80
80^2	$80 \times 80 = 6400$	$6400 - 1 \times 4757 = 1643$
80^4	$1643 \times 1643 = 2699449$	$2699449 - 567 \times 4757 = 2230$
80^8	$2230 \times 2230 = 4972900$	$4972900 - 1045 \times 4757 = 1835$

$C = 80^{13} \bmod 4757$

$= 80^8 \cdot 80^4 \cdot 80^1 \bmod 4757$

$= 1835 \times 2230 \times 80 \bmod 4757$

$= 327364000 \bmod 4757$

$= 327364000 - 68817 \times 4757 = 1531$

$M = 1531^{1777} \bmod 4757$

$= 80$